



Swinburne University of Technology
Hawthorn Campus
Department of Computing Technologies

COS30015 IT Security
 Assignment 2 - Semester 2, 2025

Part B Incident Situational Report

Due Date: AEST 23:59 on 02/11/2025.

Having investigated all the artefacts provided, a situation report update has been requested to understand the incident.

Compute the following template with your findings from your investigation.

COS30015 SITREP		
Impacted COS30015 Accounts	Student & Student ID	Nguyen Dinh Dung & 104772138
- Admin (Linux File Server): Compromised account used for system reconnaissance, data archiving, persistence creation, and exfiltration of teaching materials. - Administrat0r: Backdoor account created by the adversary with sudo and topsecret group privileges for persistent access. - Admin (Windows Webserver WS.10): Compromised account used via RDP from Tor exit node to gain initial foothold in DMZ.	Class	COS30015-IT Security
	Tutor	Dr. Hoang Xuan Tung
Incident Timeline	Impacted COS30015 Hosts	
2025-09-17 15:15: Phishing email sent to Admin from mail[.]fakeemail[.]com (183[.]81[.]169[.]238) with malicious patch.exe	WS.10 - Webserver 1 (DMZ) Impact: Entry point of the attack. patch.exe executed, PowerShell restrictions disabled,	

- link disguised as a CVE security patch. 2025-09-18 10:22: patch.exe first executed on Webserver WS.10 (DMZ). PowerShell execution policy set to Unrestricted via Base64-encoded command. 2025-09-19 14:35: patch.exe executed a second time on WS.10. 2025-09-20 08:24: Adversary RDP login to WS.10 (Admin account) from Tor exit node 171[.]25[.]193[.]25 via port 3389. 2025-09-20 11:01: Login to File Server FS.20 (Server LAN) from 192[.]168[.]100[.]10 (WS.10, DMZ) - adversary pivots from DMZ to internal network. 2025-09-20 (post-login): Adversary performs full system reconnaissance on FS.20: whoami, id, env, uname -a, lscpu, free -h, cat /etc/passwd, netstat -tuln. 2025-09-20 (post-login): Adversary creates backdoor account Administrat0r with sudo and topsecret group privileges for persistence. 2025-09-21 09:12: Admin account downloads secret-information-results-passwords.txt from File Server (192[.]168[.]11[.]20). 2025-09-20 to 09-25: Samba logs confirm ongoing unauthorized file access across Assignments, Answers, Students, Lectures, and Quiz directories. 2025-09-20 (scheduled): mal2.ps1 registers scheduled task ExerciseExerciseExercise triggering at every logon to download agent.exe and dump LSASS credentials. 2025-09-23 (dark web post): EduStrike posts stolen COS30015 data for sale including 12.3GB of assignments, quizzes, answers, lectures, tutorials, and student data.	RDP session established by adversary from Tor exit node. mal2.ps1 dropped to create persistence. Severity: Critical FS.20 - File Server (Server LAN) - Impact: Primary target. Adversary pivoted from DMZ, performed full reconnaissance, created backdoor account Administrat0r, archived all teaching data, exfiltrated via HTTP POST, and downloaded sensitive password file. Severity: Critical DC.10 - Domain Controller (Server LAN) - Impact: Potentially at risk given Admin credentials were compromised and Administrat0r backdoor account was created with elevated privileges. Severity: High User LAN (30 Desktops) - Impact: Student data confirmed exfiltrated. Potential for further targeted attacks against enrolled students. Severity: Medium
IoCs Observed	TTPs Observed
Malicious Files / Hashes	Initial Access (TA0001) T1566.001 - Spearphishing Attachment: patch.exe delivered via phishing email

• patch.exe - SHA256: 5EDF006430BED016D5935AD996C6F53F2DF2C7730AA7FC91633B9DCC7569F94C • mal2.ps1 - multi-layer obfuscated PowerShell (octal → reversed Base64 → final payload) • agent.7z / agent.exe - downloaded C2 backdoor payload • dump.bin - LSASS memory credential dump IP Addresses (Defanged) • 171[.]25[.]193[.]25 - Tor exit node used for RDP access to WS.10 • 183[.]81[.]169[.]238 - Phishing email origin IP • 192[.]168[.]100[.]10 - WS.10 (pivot source into Server LAN) • 192[.]168[.]1[.]20 - Internal IP used to download sensitive file Domains / Emails (Defanged) • mail[.]fakeemail[.]com - phishing email sender domain • phish[@]fakeemail[.]com - Reply-To address in phishing email • example[.]com/staging/patch.exe - malware delivery URL Suspicious Indicators • Backdoor account: Administrat0r (sudo + topsecret group) • Scheduled task: ExerciseExerciseExercise (AtLogOn trigger) • Stolen file: secret-information-results-passwords.txt • Exfiltrated archive: /tmp/documents_backup.tar.gz (12.3GB) • Base64-encoded PowerShell: Set-	• impersonating Ubuntu security team • T1078 - Valid Accounts: Compromised Admin credentials used for RDP and file server access Execution (TA0002) • T1059.001 - PowerShell: Base64-encoded Set-ExecutionPolicy unrestricted; mal2.ps1 multi-stage PowerShell payload • T1059.003 - CMD: cmd.exe used to run PowerShell encoded command from patch.exe Persistence (TA0003) • T1136.001 - Create Local Account: Administrat0r backdoor account created with sudo rights • T1053.005 - Scheduled Task: ExerciseExerciseExercise task registered to run at every logon Privilege Escalation (TA0004) • T1098 - Account Manipulation: Administrat0r added to topsecret and sudo groups Defense Evasion (TA0005) • T1027 - Obfuscated Files: Octal encoding, reversed Base64, and nested PowerShell obfuscation in mal2.ps1 • T1562.001 - Disable Security Tools: Set-ExecutionPolicy unrestricted disables PowerShell restrictions • T1070.004 - File Deletion: Script self-deletes after execution • T1497 - Virtualization/Sandbox Evasion: Checks RAM >2GB and disk >5GB before executing Credential Access (TA0006) • T1003.001 - LSASS Memory: rundll32 + comsvcs.dll MiniDump used to dump LSASS credentials to dump.bin • T1087 - Account Discovery: cat /etc/passwd, getent passwd, groups enumerated Discovery (TA0007) • T1082 - System Information Discovery: whoami, id, uname -a, lscpu, free -h • T1083 - File and Directory Discovery: ls -l /teaching/COS30015/2025/ • T1049 - System Network Connections: netstat -tuln Lateral Movement (TA0008) • T1021.001 - RDP: Adversary pivoted from WS.10 (DMZ) to FS.20 (Server LAN) via RDP using Admin credentials • T1090.003 - Proxy (Multi-hop): Tor exit node 171[.]25[.]193[.]25 used to anonymise RDP
--	---

ExecutionPolicy unrestricted Dark web forum post by threat actor EduStrike advertising stolen COS30015 data	access Collection (TA0009) - T1560.001 - Archive Collected Data: tar -czf /tmp/documents_backup.tar.gz used to archive teaching materials - T1005 - Data from Local System: secret-information-results-passwords.txt downloaded from File Server Exfiltration (TA0010) - T1048.003 - Exfiltration Over Unencrypted HTTP: curl -X POST used to upload archive to example[.]com/upload
Remediation Advice	
1. Immediate Response Containment - Immediately isolate WS.10 (Webserver) and FS.20 (File Server) from the network to prevent further exfiltration. - Block all inbound/outbound connections from/to Tor exit nodes at the perimeter firewall. - Remove the Administrator backdoor account immediately: <code>sudo userdel -r Administrator</code> - Delete the scheduled task ExerciseExerciseExercise from all affected Windows systems. - Reset all Admin account passwords across all systems immediately. Force credential rotation for all privileged users. Forensic Preservation - Image all affected systems (WS.10, FS.20) before any remediation to preserve forensic evidence. - Preserve /var/log/auth.log, Samba logs, and Windows Event Logs (Event ID 4624) for incident investigation. - Verify integrity of /tmp/documents_backup.tar.gz and confirm what data was exfiltrated. Regulatory Notification - Notify the Australian Information Commissioner (OAIC) under the Notifiable Data Breaches (NDB) scheme - student PII confirmed exfiltrated. - Notify the Victorian Information Commissioner (OVIC) given institutional location. - Notify affected students and staff of the data breach in accordance with the Privacy Act 1988. - Engage legal counsel regarding regulatory exposure and potential breach notification obligations. 2. Short-Term Security Hardening Network Segmentation (addressing DMZ-to-Server LAN pivot) - Implement strict firewall rules explicitly denying all DMZ-to-Server LAN direct connections. DMZ hosts must never initiate connections to internal servers. - Deploy a dedicated bastion/jump host for all administrative access to internal systems. - Restrict SSH/RDP to the File Server to trusted jump host IPs only. Authentication & Access Control - Enforce Multi-Factor Authentication (MFA) on all administrative accounts and remote access sessions. - Implement account lockout policies after failed login attempts to prevent brute-force attacks. - Apply least privilege principles - the Admin account should not have access from DMZ hosts. - Restrict file access permissions on the File Server using Role-Based Access Control (RBAC).	

Endpoint Security

- Deploy Endpoint Detection & Response (EDR) on all servers to detect malicious process execution and lateral movement.
- Enable PowerShell script block logging and constrained language mode across all Windows systems.
- Enable auditd on Linux systems to record all command execution with timestamps.
- Configure HISTTIMEFORMAT in bash to timestamp all command history entries.

3. Long-Term Strategic Improvements

- Implement a SIEM (Security Information and Event Management) platform to centralise and correlate logs from all systems.
- Deploy Data Loss Prevention (DLP) solutions to monitor and alert on large file transfers and unusual data movement.
- Implement Zero Trust Network Access (ZTNA) to replace open RDP access.
- Conduct regular security awareness training focused on phishing identification for all staff.
- Implement email filtering with SPF, DKIM, and DMARC to detect spoofed sender domains.
- Establish an Incident Response Plan with defined roles, escalation paths, and communication procedures.
- Perform regular penetration testing and vulnerability assessments of the DMZ and Server LAN infrastructure.

Maintain offsite, immutable backups of all teaching materials and student data with regular restore testing.

